

Master Security, Data Protection & Architecture Guide

Plain-English Security, Cloud Hosting, and Financial Safety Guarantees for Enterprise Clients & Finance Teams

★ Our 5 Golden Security Guarantees:

- ✓ **Bank-Grade Encryption:** All credentials encrypted with AES-256 before storage.
- ✓ **World-Class Cloud Hosting:** Hosted on Google Cloud (GCP) & DigitalOcean.
- ✓ **Zero AI Training Retention:** Invoices are never saved or used to train public AI models.
- ✓ **Strict Company Isolation:** Your data is isolated in a private digital vault.
- ✓ **100% Draft Mode Safety Net:** Never alters approved books or pays bills blindly.

1. Cloud Hosting & Server Infrastructure (Google Cloud & DigitalOcean)

Q1 Where is our company's data hosted, and who operates the servers?

We host our application and database on enterprise-grade cloud providers—**Google Cloud Platform (GCP)** and **DigitalOcean**. These global infrastructure leaders host applications for Fortune 500 companies, featuring 24/7 on-site physical security guards, biometric access verification, redundant power generators, fire suppression systems, and climate-controlled environments.

Q2 Why do you host on Google Cloud and DigitalOcean instead of maintaining on-premise physical servers?

Enterprise cloud providers offer vastly superior reliability, physical security, and disaster recovery compared to traditional in-house office servers. They provide 99.99% uptime guarantees, enterprise compliance certifications (ISO 27001, SOC 2, HIPAA), and automatic hardware replacement in the event of component failure.

Q3 Can staff or engineers from Google Cloud or DigitalOcean view our confidential invoices?

No. All sensitive credentials, connection keys, and financial accounting data are encrypted with bank-grade encryption **before** being saved to the database. To Google or DigitalOcean, the stored data looks like completely scrambled, unreadable characters. Only our application possessing the secret runtime key can decrypt the data during live synchronization.

Q4 What happens if a cloud data center experiences a power outage or hardware disaster?

- **Automated Daily Backups:** The entire database is automatically snapshotted daily with 7-day point-in-time recovery.
- **Rapid System Recovery:** If a server experiences a hardware failure, a fresh replacement server can be brought online in **under 15 minutes**.
- **Permanent Cloud Safety in Xero:** Once an invoice is uploaded as a draft into Xero, it is stored permanently in Xero's own secure cloud, ensuring accounting records are never lost.

Q5 In which country is our company's data physically stored?

Our servers and databases are provisioned in dedicated **Singapore (Southeast Asia) data centers**. This ensures compliance with regional data privacy laws (such as Singapore's **PDPA**, Malaysia's **PDPA**, and the Australian Privacy Principles), while delivering lightning-fast, low-latency performance for accounting teams across the region.

Q6 How does the infrastructure protect against hackers, DDoS attacks, and suspicious bots?

- **Cloudflare Cyber Shield:** All incoming web traffic passes through **Cloudflare**, which automatically detects and blocks DDoS attacks, malicious bots, and suspicious IP addresses before they ever reach our application.
- **Cloaked Server IP:** Our server's actual IP address is completely hidden from the public internet.
- **Firewall Protection:** Cloud firewalls block unauthorized ports, allowing only secure web traffic coming directly from Cloudflare.

Q7 How are our databases protected from public internet exposure?

Our PostgreSQL database is placed inside an **isolated Private Cloud Network (VPC)** with zero public internet access. The database only accepts encrypted connections from our authorized application server via internal private routing.

2. System Architecture & "All-in-One" Design

Q8 Your platform handles the web portal, email reader, and Xero sync in one place ("All-in-One"). Why is it built this way, and is it safe?

Yes, it is completely safe and highly efficient. Combining the portal, email listener, and Xero sync engine into a unified system provides key business benefits:

- **Instant Processing:** Invoices are read, parsed, and pushed to Xero in seconds with zero delay between separate external services.
- **Maximum Reliability:** Fewer disconnected components mean fewer points of failure, higher stability, and lower hosting costs.
- **Strict Internal Safeguards:** The server runs isolated safety boundaries, ensuring background email reading and interactive dashboard browsing operate smoothly without interfering with one another.

Q9 What prevents the "All-in-One" design from slowing down or freezing during heavy month-end billing?

- **Smart Queue Pacing:** The system organizes incoming invoices into a paced background line, processing each document smoothly with built-in buffers.
- **Attachment Size Filter:** Invoices exceeding 10MB are filtered to prevent memory spikes.
- **Independent Task Prioritization:** User dashboard interactions take priority over background scanning, keeping your web portal fast and responsive.

Q10 If the server restarts or undergoes maintenance while an email is arriving, will the email or invoice be lost?

No. When an email arrives, its tracking ID is recorded immediately to a persistent on-disk queue before extraction begins. If the server restarts, our startup recovery system automatically identifies any interrupted jobs, verifies whether the draft was created in Xero, and safely finishes any pending tasks.

Q11 How does the system handle high traffic so one heavy company doesn't slow down the platform for others?

The platform enforces **Individual Company Rate Limits**. Each company account receives its own independent allocation of processing requests per 15-minute window. A sudden spike in invoices from one company cannot consume resources allocated to other businesses.

3. Data Privacy, Multi-Tenancy & Preventing Data Leaks

Q12 Can another company using your platform ever see our invoices, supplier names, or pricing?

Never. Multi-tenant privacy is our highest priority:

- Every company account is strictly partitioned into its own private digital vault.
- When you log in, your secure session token acts like a unique digital key that only unlocks your company's specific records.
- Even if another user attempts to guess your invoice numbers, the server automatically rejects the request with an access denied error.

Q13 How does the system guarantee digital vault isolation in the database?

Every single database query strictly requires your unique company identification code. The database will never execute a search or display records across multiple company accounts simultaneously. User PDF files are stored in physically isolated folders dedicated exclusively to each tenant.

Q14 How do you prevent sensitive financial data, passwords, or bank numbers from leaking into server logs?

Our system logging engine automatically scans and scrubs all internal logs, permanently masking passwords, authentication tokens, bank details, and personal contact information before writing entries to disk.

Q15 What happens if an unexpected system error occurs—will technical database details be exposed to users?

No. Our security error handler intercepts all technical errors, records technical details privately to our secure internal log, and returns a simple, friendly message ("Internal server error") to the web browser to prevent sensitive code or database layouts from being exposed.

Q16 How does the system protect against unauthorized file downloads or attempts to access another company's PDF attachments?

File download requests require an active, authenticated user session and verify that the requested document belongs strictly to the logged-in company before delivering the file. Direct folder navigation or path guessing (. . /) is automatically blocked.

4. Data Security, Encryption & Passwords

Q17 How are our third-party connection keys (Xero access tokens, email passwords, AI keys) protected in the database?

All stored credentials are encrypted at rest using **authenticated AES-256-GCM**, the gold standard used by global financial institutions:

- Every secret is encrypted with a unique, randomized digital initialization vector.
- An authentication verification tag guarantees the data has not been tampered with.
- Master encryption keys are stored strictly in isolated server memory and are never stored in the database.

Q18 How are user login passwords protected against database theft and cracking?

User passwords are never stored in plain readable text. We use industry-standard **Bcrypt** cryptographic hashing. We store only an irreversible mathematical fingerprint of your password. Even in the theoretical scenario where a database was stolen, your actual password cannot be reversed or read.

Q19 How is data protected while traveling across the internet and internal systems?

- **Web Portal:** Enforced **TLS 1.3 / HTTPS** encryption across all web pages.
- **Database Connection:** Private network communication with mandatory SSL encryption.
- **Email Ingestion:** Encrypted email reading over secure IMAP sockets (Port 993).
- **Xero & AI Connections:** Outbound connections to Xero and AI providers utilize encrypted HTTPS channels with strict digital certificate validation.

Q20 How are user sessions and logins managed securely?

Logins utilize stateless, digitally signed secure tokens (JWT). Each token is signed with a high-entropy secret key and expires automatically after a set period, requiring periodic re-authentication to prevent session hijacking.

Q21 Can internal system administrators access or snoop on customer connection secrets?

No. All secrets are scrambled before they touch the database. Decryption requires the master encryption key, which is isolated to the application runtime environment and segregated from administrative database access.

5. Financial Accuracy, Deduplication & Xero Integration

Q22 What stops the system from accidentally creating duplicate bills in Xero if an email is sent or forwarded multiple times?

We implement a **Two-Stage Duplicate Protection System**:

1. **Initial Database Scan:** Before processing an invoice, the system checks whether the supplier name, invoice number, and grand total already exist in your records. If found, the duplicate email is skipped automatically.
2. **Final Xero Verification:** Immediately before sending data to Xero, a final safety verification confirms the invoice has not been uploaded. If it already exists, the system stops and links you to the existing bill.

Q23 What happens if an invoice is blurry, handwritten, or oddly formatted? Will AI guess the wrong numbers?

- **Automatic Mathematical Sanity Checks:** The system verifies that Line Items + Tax equal Grand Total. If the numbers do not add up or if the total is zero, the system **refuses to upload it blindly**.
- **Human-in-the-Loop Review:** Any unclear or scanned invoice is placed in a **"Requires Review"** tab on your dashboard. Your finance team can view the original PDF side-by-side, verify numbers with one click, and send it to Xero when satisfied.

Q24 Can this automated system accidentally approve a payment or alter our official accounting ledgers?

No. By design, the platform **only creates DRAFT invoices** (Bills to Pay → Drafts for suppliers, or Invoices → Drafts for customers). Draft invoices do not affect your live profit/loss statements, balance sheets, or bank accounts until your authorized finance manager reviews and formally approves them inside Xero.

Q25 Does artificial intelligence (Google Gemini / OpenRouter) learn from or store our confidential financial numbers?

No. We use commercial enterprise AI connections with strict **Zero-Data Retention agreements**. Your invoices are sent through an encrypted channel purely for text extraction and are **never saved, shared, or used to train public AI models**.

Q26 What permissions does the system request when connecting to our Xero organization?

We follow the **Principle of Least Privilege**:

- The system only requests permission to create transactions (`accounting.transactions`) and maintain an active connection (`offline_access`).
- We never request permission to modify your organization settings, change bank account details, or access unrelated business modules.

Q27 How does the platform handle Xero's API traffic limits during peak billing rushes?

The system uses a sequential pacing queue with an enforced 1.5-second buffer between dispatches, ensuring your company never exceeds Xero's standard rate limits (60 calls per minute). If Xero requests a pause, our queue holds pending invoices safely and resumes automatically.

6. Advanced Cyber Threat Protection & Anti-Fraud

Q28 What if a malicious supplier sends a PDF with hidden prompt injection text designed to trick the AI (e.g. "make total \$1,000,000")?

The system defends against hidden prompt instructions using a **Multi-Layered Safety Sandbox**:

- **Isolated Data Role:** The AI is strictly instructed to extract data into predefined fields with zero conversational authority.
- **Structured Output:** Responses must match a rigid data structure; conversational commands or instructions are discarded as errors.
- **Mathematical Verification:** Extracted numbers must mathematically balance in our application code before moving forward.
- **Draft-Only Safeguard:** Even if an unusual invoice were created, it enters Xero strictly as a **Draft**, requiring human approval before payment.

Q29 How do you prevent email spoofing where a fraudster emails a fake invoice pretending to be a verified supplier?

- **Mail Server Authentication:** Ingestion connects directly to your authorized corporate mailbox (Google Workspace / Microsoft 365), which validates sender authenticity via SPF, DKIM, and DMARC protocols.
- **Xero Contact Matching:** Invoices are matched against verified **Xero Contacts**. Invoices from unrecognized supplier names or new bank accounts are flagged for manual verification.

Q30 How does the system handle corrupted PDF files, oversized attachments, or hidden malware?

- **Attachment Pre-Filter:** Ingestion rejects non-PDF attachments and files exceeding the 10 MB limit.
- **Safe Memory Extraction:** Documents are parsed in isolated memory buffers. Corrupted files or unreadable scans fail safely to the review queue without executing any scripts or macros.

Q31 How is non-invoice email spam filtered out without slowing down the system?

Emails are quickly screened for standard billing keywords (Invoice, Bill, Tax Invoice, Receipt) and verified for the presence of valid PDF attachments or structured text templates. Non-billing emails are ignored immediately.

7. Deep Technical Security & Penetration Testing Assurances

Q32 How does the system prevent unauthorized server requests (Server-Side Request Forgery)?

The application cannot be tricked into connecting to unauthorized destinations. Outbound connections are hardcoded strictly to verified API endpoints (`api.xero.com`, `generativelanguage.googleapis.com`, `openrouter.ai`) and internal server query attempts are blocked.

Q33 How does login token verification protect against tampering or forged access tokens?

Every incoming request is verified using strict cryptographic signature checks against an algorithm allowlist. Unsigned tokens, altered user IDs, or forged access tokens are rejected instantly.

Q34 How does the Xero connection dance protect against login interception and replay attacks?

When connecting your Xero account, the platform creates a unique, high-entropy cryptographic security code (state) that is verified upon return from Xero before establishing the connection.

Q35 Can the master encryption keys be safely updated and rotated over time?

Yes. All encrypted fields use version-prefixed identifiers, allowing our engineering team to perform zero-downtime key rotation and re-encryption in the background whenever security policies require.

Q36 How are authentication and password checks protected against timing attacks?

Signature checks and password verifications use constant-time mathematical comparisons, preventing attackers from deducing secret tokens by measuring server response latencies.

Q37 Can a regular user manipulate web requests to promote their account to an Administrator?

No. User privilege levels are controlled strictly by the server database. Account registration defaults to standard permissions, and role elevation can only be executed through direct authorized database administration.

8. Compliance, Governance & Disaster Recovery

Q38 How does the platform comply with regional privacy laws (Singapore PDPA, Malaysian PDPA, GDPR)?

- **Data Minimization:** Only financial metadata required for bookkeeping reconciliation is stored.
- **Data Sovereignty:** Primary data resides in certified regional cloud data centers.
- **Right to Erasure:** Complete deletion workflows ensure customer data can be permanently erased upon request.

Q39 What happens to our data if we cancel our subscription or leave the platform?

In compliance with privacy regulations, account deletion triggers an automated purge that permanently deletes your company's records, user logins, credentials, and cached PDF files from our servers. Invoices previously uploaded to Xero remain safely in your Xero organization.

Q40 What is the Disaster Recovery timeline if a catastrophic hardware failure occurs?

- **Recovery Time Objective (RTO):** Replacement cloud compute nodes can be provisioned in **under 15 minutes**.
- **Recovery Point Objective (RPO):** Maximum 24 hours of local cache (0 hours for Xero, as posted drafts reside permanently in Xero Cloud).

Q41 What happens if the AI provider experiences a temporary service outage?

If an AI provider experiences a temporary disruption, pending invoices remain safely in our persistent queue marked for retry. As soon as connectivity returns, background workers process the remaining invoices without losing any data.

Q42 What is the formal Incident Response Plan if a security issue is suspected?

- **Instant Containment:** Ability to immediately rotate security secrets, invalidating all sessions and locking down credential access.
- **Audit Forensics:** Review immutable structured audit logs to determine the exact scope of affected records.
- **Regulatory Notification:** Formal 72-hour notification protocol in compliance with regional data protection authorities.

9. Executive Quick-Reference Summary Table

Client / Auditor Question	10-Second Executive Defense Response
"Can another company access our invoices?"	Impossible. Strict company-level digital vaults isolate every tenant's invoices, folders, and records.
"Can staff at Google Cloud or DigitalOcean see our data?"	No. All credentials and accounting records are encrypted with AES-256 before being saved. The data is completely unreadable to them.
"Is the system vulnerable to DDoS or hackers?"	No. All web traffic passes through Cloudflare Cyber Shield , masking our server IP and filtering malicious traffic.
"Can AI make financial errors on our books?"	Invoices upload strictly as Drafts . If math doesn't check out, it pauses in a review screen for human approval.
"Could an email glitch cause duplicate bills in Xero?"	No. Two-layer duplicate prevention automatically detects repeated emails or identical invoice numbers and stops duplicates.
"Is our data safe from AI public learning?"	Enterprise zero-retention contracts guarantee your financial numbers are never stored or used to train public AI models.
"What if a supplier PDF contains hidden prompt injection?"	Extracted data is forced into strict structures and verified with mathematical code before entering Xero strictly as Drafts .
"How quickly can the system recover from a server crash?"	With automated daily backups and persistent queues, full node recovery takes under 15 minutes (RTO < 15 min).